Author: Andrey Pautov. Published on Medium

Detecting Malicious Insider Activity: A Technical Detection Engineering Guide

Detection logic, case evidence from 14 documented incidents, and a four-phase implementation programme — covering deterministic rules, behavioural heuristics, UEBA, exfiltration path coverage, and the telemetry required before any of it works.

By Andrey Pautov — April 2026

> ***Epistemic labels:*** *[Documented] = a cited source explicitly states this. [Inferred] = a reasonable analytic conclusion derived from documented facts or established detection engineering practice. Unlabelled claims have consensus support in the cited literature. This guide is not legal advice.*

Table of Contents

- Introduction
  1. Why Insider Detection Is Structurally Harder
  2. Insider Threat Taxonomy and Kill Chain
  3. Documented Case Studies
  4. Detection Methods
- 4.1 Deterministic Rules
- 4.2 Behavioural Heuristics
- 4.3 Identity and Privilege Anomalies
- 4.4 Exfiltration Path Coverage
- 4.5 Sabotage Signals
- 4.6 UEBA and Anomaly Models

- 4.7 Covering-Tracks Detection

5. Detection Priority Matrix
6. Required Telemetry
7. Legal and Privacy Constraints
8. Implementation Guidance
9. Conclusion and Coverage Gaps
10. References

Introduction

This guide is a technical detection engineering reference for analysts, security architects, and programme leads responsible for detecting malicious insider activity in enterprise environments. Its focus is **operationalisable detection**: every method described identifies a specific log source, event, or telemetry field, and every claim is either grounded in a cited primary source or explicitly labelled [Inferred].

Scope. This guide covers malicious insiders — employees, contractors, and privileged users who intentionally cause harm through data theft, sabotage, financial fraud, or espionage. Negligent insiders (accidental data loss, misconfiguration) are not covered; their detection posture differs substantially. Compromised insiders (external attackers operating through a taken-over account) are noted where detection overlaps.

Evidence base. Detection claims are grounded primarily in CERT/CMU case research [4], DOJ criminal records and indictments, regulatory findings (OPC PIPEDA, UKSC), and published IR data (Ponemon, Verizon DBIR, Mandiant M-Trends). Fourteen real cases (§3) are analysed for signals present in retrospect, what was missed, and what triggered detection. Where no primary source exists for a detection claim, it is marked [Inferred].

How to use this guide.

- **Build a new programme**: start with §8 Implementation Guidance and work backwards into the relevant §4 subsections. The phased approach is structured to deliver maximum ROI first.
- **Triage an active investigation**: use §3 to pattern-match case type, then §4 for the specific telemetry and logic relevant to your scenario.
- **Audit an existing programme**: use §5 Detection Priority Matrix to identify gaps and confirm correct tier placement of deployed controls.
- **Legal and compliance review**: §7 covers monitoring constraints under US law, GDPR, and the Australian Privacy Act.

What this guide does not provide. Specific product configuration instructions, vendor-specific SIEM query syntax, production-ready threshold values (these must be calibrated per environment), or legal advice.

---

1. Why Insider Detection Is Structurally Harder

Insider threat detection is structurally harder than external attack detection for a single reason: **the attacker is already authenticated**. There is no perimeter to cross, no credential to steal, no exploit to fire. The insider has a valid account, knows where sensitive data lives, understands what monitoring exists, and can operate at a pace that blends into normal work activity.

External attacker detection relies on the contrast between attacker behaviour and the environment's baseline — unusual protocols, new source IPs, first-logon anomalies, unexpected tools. The insider *is* the baseline. Their legitimate access is the attack vector.

Key structural differences from external threats

- No initial access phase — the insider already has it
- Lateral movement may be entirely absent — the insider reaches their target directly
- Exfiltration channels overlap with legitimate work tools: email, cloud sync, USB, print, SaaS
- The attacker understands operational rhythms and monitoring gaps
- Motivation is often invisible until after the act — financial pressure, grievance, ideology, coercion
- HR and business context (resignation, performance dispute, role change) are frequently the strongest pre-attack signals, not technical telemetry

Statistical context

The CERT/CMU Insider Threat Center has documented more than 1,500 cases across its research programme (as stated in the 7th edition [4]; the database continues to grow), spanning IT sabotage, IP theft, fraud, and espionage categories. These cases form the empirical foundation for the detection patterns in this guide.

Several industry surveys track insider incident metrics across wider populations. The Cybersecurity Insiders annual Insider Threat Report [1] and the Verizon Data Breach Investigations Report [2] provide broader cross-industry context; the DBIR's "internal actor" category encompasses both malicious insiders and negligent human error and should not be read as a measure of malicious insider prevalence alone [2].

On detection method: the CERT/USSS banking-and-finance sector study found that 61% of insider incidents were detected by people not responsible for security, and only 22% were caught by auditing or monitoring

procedures. Logs were used for attribution in 74% of cases where the insider's identity was eventually established — meaning logs are most often a forensic tool rather than a detection trigger [4]. This finding is specific to the banking and finance sector and may not generalise precisely to all industries, but the directional pattern is consistent with findings across CERT's broader case database.

On incident containment: the 2023 Ponemon Cost of Insider Risks Global Report found that organisations took an average of 86 days to contain an insider incident [3]. This figure covers the full lifecycle from initial identification to containment, not dwell time before first detection.

The detection paradox

The most dangerous insider — technically sophisticated, patient, motivated — is also the one most likely to understand and evade the controls in place. The cases that are detected are frequently caught by non-technical means: a colleague tip, an external referral, a law enforcement notification, or a forensic artefact left during covering-tracks activity. Building a programme that supports and amplifies human observation is as important as the detection engineering itself.

Where DLP consistently fails

DLP fails most consistently when the programme is content-only, threshold-only, or channel-limited. It struggles when:

- The actor copies data to a workstation and then to removable media in sub-threshold chunks
- The exfiltration channel is an approved SaaS workflow
- The destination is hidden behind long-lived OAuth tokens or encrypted messaging
- The exfiltration is transformed into print, screenshots, or staged archives rather than raw document transfer
- The encoding is steganographic — legitimate-looking image files carrying hidden payloads

The Desjardins regulatory findings are the most explicit documentation of this failure: over at least 26 months, an insider's activity was not detected because monitoring was partial, log review was passive, and transfer controls were threshold-based rather than sensitivity-aware. The Office of the Privacy Commissioner of Canada explicitly required that monitoring cover access and transfers below the minimum volume threshold [16].

Privileged users versus standard employees

Detection differs materially by user type. CERT's sabotage research found that most sabotage insiders held technical or privileged roles and that administrator access was common [4]. These users can create persistence, alter logs, destroy backups, or make destructive changes that look like normal administration

unless control-plane actions are monitored separately. Standard employees are more often detected through repository-drain patterns, role-scope deviations, departure-linked volume spikes, and human observation.

---

2. Insider Threat Taxonomy and Kill Chain

2.1 Threat Categories

The CERT/CMU Division classifies insider threats across three primary types, based on analysis of more than 1,500 documented cases [4]:

Malicious Insider — intentional harmful action for personal gain, revenge, ideology, or coercion. Subdivided by goal:

- **Data theft and IP exfiltration** — stealing proprietary information, source code, customer data, or trade secrets. The most common category. Frequently correlates with job transition, competitor recruitment, or nation-state tasking.
- **Sabotage** — deliberate destruction or disruption of systems, data, or business processes. Often triggered by termination, disciplinary action, or sustained grievance. Less frequent than IP theft but high-impact per incident.
- **Financial fraud** — manipulation of financial systems, ghost vendors, or unauthorised transactions. High prevalence in finance, accounting, and IT admin roles with access to payment systems.
- **Espionage** — acting as an agent for a foreign government or corporate intelligence interest. Often indistinguishable from IP theft until a full investigation is underway.

Negligent Insider — accidental harm through misuse, misconfiguration, or policy disregard. Not covered in this guide; detection approaches differ significantly.

Compromised Insider — a legitimate account taken over by an external attacker. Detection overlaps with insider methods but the attacker profile and motivation differ. Distinguished where relevant below.

Departing Employee — the 30–90 day window around resignation or termination is consistently the highest-risk period across CERT case data [4]. Behaviour patterns shift: unusual access hours, access to data outside current role, bulk downloads, and data staging.

2.2 The CMU SEI Insider Threat Kill Chain

The CERT Division's kill chain model identifies the following phases [4]. Phases are not strictly sequential and some may be skipped:

Phase 1 — Predisposition. Pre-existing psychological, financial, or ideological factors that create susceptibility. Not technically observable. Requires HR, management, and peer awareness.

Phase 2 — Stressor. A triggering event: termination, demotion, disciplinary action, financial crisis, external recruitment, or coercion. May leave HR signals but rarely technical artefacts.

Phase 3 — Planning. Identifying what to take, how, and through which channels. May produce early technical artefacts: access pattern changes, tool downloads, testing of exfiltration paths.

Phase 4 — Preparation. Acquiring tools, staging access, testing channels, creating alternative access mechanisms. Detection opportunity: unusual process execution, new sync client installation, forwarding rule creation, access to systems outside normal role scope.

Phase 5 — Action. The primary harmful act: bulk copy to removable media or personal cloud, deletion of infrastructure, malicious code commit, fraudulent transactions.

Phase 6 — Post-incident. Covering tracks, denying involvement. Detection opportunity: log clearing, file timestamp modification, anti-forensic tool execution, physical media destruction.

Critical observation: Most technical detection opportunities are concentrated in phases 3–6. Phases 1–2 require non-technical signals. Programmes that rely solely on technical controls miss the early warning window that CERT's data shows is often present weeks or months before the primary harmful act. CERT's sabotage dataset found that 80% of cases showed concerning behaviour beforehand visible to supervisors, and the substantial majority were detected because a system failure or operational irregularity occurred — not by pre-action monitoring [4] (Specific percentage figures vary across CERT editions and study cohorts; see CERT 7th Ed. for the most current figure.).

---

3. Documented Case Studies

The following cases are drawn from DOJ press releases, criminal complaints, appellate records, regulatory findings, and court judgments. Each entry documents: what happened, signals present in retrospect, what was missed, what triggered detection, and the primary detection lesson. Secondary press sources are used only where primary documents are not publicly accessible.

3.1 Chelsea Manning — US Army Intelligence Analyst (2010)

Category: Espionage / mass data exfiltration | **Organisation:** US Army

Manning downloaded approximately 750,000 classified US government documents, diplomatic cables, and battlefield reports from the Secret Internet Protocol Router Network (SIPRNet) over several months, using a rewritable CD. The data was transmitted to WikiLeaks. [Documented — DOJ charging documents, US Army court-martial record]

Signals present in retrospect: Anomalous download volume from SIPRNet. Repeated removable media use on a classified network. Prior reported behavioural and disciplinary concerns that were not escalated to security personnel. [Documented — US Army court-martial record]

What was missed: No DLP on removable media. No volume-based anomaly detection on SIPRNet download activity. HR and command signals were not integrated with technical monitoring. A continuous evaluation programme was not active at Manning's unit. [Documented — Congressional hearing findings]

What triggered detection: A tip from Adrian Lamo, to whom Manning had disclosed the activity. Technical controls did not detect the exfiltration. [Documented]

Key detection lesson: [Inferred] Physical exfiltration via writable optical or portable media is invisible to technical controls if removable media DLP is absent. The behavioural and command-level signals were present; the programme to act on them was not.

3.2 Edward Snowden — NSA Contractor (2013)

Category: Espionage / data exfiltration | **Organisation:** NSA / Booz Allen Hamilton

Snowden, a system administrator contractor at the NSA, exfiltrated a large volume of classified files from NSA systems, primarily to removable media. He used his sysadmin access to reach files outside his operational assignment and, according to the NSA Inspector General report, obtained credentials from colleagues under the pretext of needing them for system administration tasks. [Documented — NSA Office of Inspector General, 2016]

Signals present in retrospect: Sysadmin accessing files outside his operational scope. Credential use that did not match the nominal account owners' normal access patterns. High-volume, scripted file downloads. Insider threat programme not deployed to the NSA facility in Hawaii where Snowden worked. [Documented — NSA OIG report; Congressional findings]

What was missed: No continuous monitoring of sysadmin activity. No need-to-know enforcement at the document level for privileged accounts. No anomaly detection on access scope or credential use inconsistencies. [Documented — NSA OIG report]

What triggered detection: Snowden departed the country before any detection occurred. Discovery was via journalistic publication of the disclosed documents. [Documented]

Key detection lesson: [Inferred] Privileged users (sysadmins, contractors with elevated access) require monitoring separate from standard users. Access-based need-to-know enforcement and anomaly detection on privileged account scope are prerequisites. The credential-sharing pattern — documented in the NSA OIG report — was a detectable identity anomaly.

3.3 Roger Duronio — UBS Systems Administrator (2002)

Category: Sabotage (logic bomb) | **Organisation:** UBS PaineWebber

Duronio, a disgruntled UBS systems administrator who had been denied a bonus, planted malicious code on more than 1,000 computers and servers across UBS's network, timed to execute the morning after he resigned. The code deleted files, causing more than $3 million in damage and disrupting brokerage operations. Duronio also shorted UBS stock in anticipation of the attack. [Documented — DOJ press release, criminal complaint, sentencing record]

Signals present in retrospect: Prior grievance and disciplinary history. Unusual scheduling activity on production servers. Scripts placed outside normal change windows. A financial position that would profit from UBS stock decline. [Documented — trial record]

What was missed: Admin-action auditing that would have detected unusual scheduled task or script creation outside a change window by a non-IT-automation account. Pre-trigger behavioural monitoring. CERT's sabotage data shows 80% of sabotage cases displayed concerning behaviour beforehand visible to management [4].

What triggered detection: The destructive execution of the code — a system failure event — triggered investigation and forensic attribution. [Documented]

Key detection lesson: [Inferred] Logic bombs are detectable before execution through monitoring of scheduled task creation by non-standard accounts outside change windows. By the time the code fires, detection is too late for prevention.

3.4 Anthony Levandowski — Waymo Engineer (2016)

Category: Departing employee / IP theft | **Organisation:** Waymo (Alphabet) → Otto → Uber

Levandowski, a senior Waymo engineer, downloaded more than 14,000 confidential files totalling approximately 9.7 GB from Waymo's internal systems before resigning, connected removable media for an extended period, and reformatted his laptop shortly before departure. He subsequently founded a competing autonomous vehicle company that was acquired by Uber. He pleaded guilty to trade secret theft in 2020. [Documented — DOJ press release, criminal complaint; Waymo civil complaint]

Signals present in retrospect: Concentrated repository access across LiDAR and hardware design systems. Extended removable media attachment during the departure window. Mass file download preceding resignation. Anti-forensic laptop reformat. [Documented — criminal complaint]

What was missed: Heightened monitoring was not triggered for a senior technical engineer in the notice window. No DLP alert on the volume of the bulk download. [Inferred from documented case facts]

What triggered detection: During adversarial civil litigation, a Waymo subpoena served on a common LiDAR component supplier produced compelled documentation showing that Uber's LiDAR hardware design replicated Waymo's proprietary circuit board — identified through litigation discovery, not through internal detection controls. [Documented]

Key detection lesson: [Inferred] The departure window for senior staff with access to crown-jewel IP requires heightened monitoring. The mass download volume, extended removable media connection, and subsequent laptop reformat were all detectable in endpoint and file-server logs.

3.5 Sudhish Kasaba Ramesh — Cisco Engineer (2018)

Category: Sabotage / post-termination access | **Organisation:** Cisco Systems

Ramesh, a former Cisco engineer, retained access to Cisco's AWS cloud environment for approximately five months after resignation because his credentials were not revoked. He deployed code from his personal Google Cloud account that deleted 456 virtual machines supporting the Cisco WebEx Teams platform, taking the service offline for approximately two weeks and affecting approximately 16,000 WebEx Teams accounts. Cisco's remediation cost approximately $1.4 million. [Documented — DOJ press release, criminal complaint]

Signals present in retrospect: Post-departure authentication to a production AWS environment using credentials that should have been revoked. Access originating from a personal external cloud account. Bulk

VM deletion — 456 resources in a concentrated burst — visible in CloudTrail management event logs. [Documented — criminal complaint]

What was missed: Credentials not revoked on resignation. No alerting on authentication by a departed employee's account. No real-time alerting on mass resource deletion at that volume. CloudTrail logs were available but reviewed forensically after the outage rather than monitored in real time. [Inferred from documented facts]

What triggered detection: The service outage itself. [Documented]

Key detection lesson: [Inferred] Post-termination access is among the most reliable and actionable deterministic signals available. The `TerminateInstances` API call volume was a high-signal event in CloudTrail. Neither control — departure-credential revocation nor bulk-deletion alerting — was in place.

3.6 Xiaoqing Zheng — GE Aviation Engineer (2019 indictment)

Category: Espionage / IP theft (nation-state adjacent) | **Organisation:** General Electric Aviation

Zheng, a GE turbine design engineer, stole proprietary turbine design files over an extended period of employment to benefit Chinese state-affiliated interests. His primary exfiltration method was steganography: he embedded GE proprietary files inside ordinary-looking image files and emailed them to his personal Hotmail account. He was indicted in 2019 and convicted at trial in 2023. [Documented — DOJ indictment; DOJ trial press release]

Signals present in retrospect: Outbound corporate email to a personal Hotmail address containing image attachments. Images with anomalously large file sizes relative to their visual content dimensions. Repeated sending pattern to the same external destination over months or years. No legitimate business communication history with those external recipients. [Documented — indictment]

What was missed: DLP was not configured to detect steganographic content. Email to personal consumer domains was not consistently alerted. The exfiltration channel operated undetected for years. [Inferred from documented indictment timeline]

What triggered detection: FBI counterintelligence referral. GE's internal systems did not identify the exfiltration. [Documented]

Key detection lesson: [Inferred] Keyword-based DLP fails entirely against steganographic exfiltration. Detection requires either specialised steganalysis tools that perform statistical analysis of pixel-level distributions (chi-square analysis of least-significant bits, RS analysis, Sample Pair Analysis) or DCT

coefficient histogram patterns in JPEG files — capabilities that are not present in any standard commercial DLP product — or behavioural controls: long-running relationship between a corporate email account and a personal webmail domain with consistent attachment sending is a detectable pattern even without content inspection.

3.7 Andrew Skelton — Morrisons Internal Auditor (2014)

Category: Disgruntled insider / data exfiltration | **Organisation:** Morrisons (UK supermarket)

Skelton, a Morrisons internal auditor who held a grievance over a prior disciplinary matter, extracted payroll data for 99,998 Morrisons employees from the PeopleSoft HR system and posted it to a file-sharing site, then mailed it on CD to three newspapers. Skelton was convicted of fraud, computer misuse, and unlawful disclosure of personal data. In civil proceedings, the High Court and Court of Appeal initially found Morrisons vicariously liable; the UK Supreme Court reversed those decisions and found Morrisons was NOT vicariously liable for the deliberate wrongdoing of an employee acting to harm the employer — a landmark ruling narrowing vicarious liability for deliberate employee wrongdoing. [Documented — UK Supreme Court judgment [2020] UKSC 12]

Signals present in retrospect: Prior documented grievance and disciplinary history. TOR network access from a corporate laptop. Extraction of a complete employee dataset from PeopleSoft by a single user account. Copying to personal removable media. [Documented — judgment]

What was missed: Monitoring of privacy-sensitive bulk dataset exports. Detection of network-anonymisation tooling on corporate devices. Alerting on full-dataset exports by individual accounts. [Inferred from documented facts]

What triggered detection: A newspaper contacted Morrisons before publication. Internal controls did not detect the exfiltration. [Documented]

Key detection lesson: [Inferred] Bulk export of an entire sensitive dataset by a single account is a high-signal event. TOR network tooling on a corporate device is a strong indicator of intent to evade monitoring and should generate an alert regardless of what data is subsequently accessed.

3.8 Reyes Daniel Ruiz — Yahoo Software Engineer (2018)

Category: Privilege abuse / personal misuse | **Organisation:** Yahoo

Ruiz, a Yahoo software engineer, used his work access to compromise approximately 6,000 user accounts, searching for intimate images and videos. He then used Yahoo credentials to pivot into external accounts (iCloud, Facebook, Gmail, Dropbox) belonging to the same users. Upon detection, he destroyed the laptop and external hard drive used to store the material. [Documented — DOJ press release, criminal complaint]

Signals present in retrospect: Repeated access to user accounts with no associated business purpose or service ticket. Cross-account pivoting from Yahoo credentials into external services. High access volume across individual user accounts outside normal operational patterns. [Documented — complaint]

What was missed: Purpose-binding controls linking user-data access to an open service ticket. Alerting on unusual account lookup patterns (volume, non-sequential access, absence of operational correlation). [Inferred from documented facts]

What triggered detection: Employer observation of suspicious account activity. [Documented]

Key detection lesson: [Inferred] Privileged access to user data requires both purpose-binding (access must correlate with an open ticket) and anomaly detection on access patterns. The cross-account pivoting into external services was an access velocity and scope anomaly detectable in user-data access logs.

3.9 Nickolas Sharp — Ubiquiti Developer (2020–2021)

Category: Data theft / extortion / insider posing as external attacker | **Organisation:** Ubiquiti Networks

Sharp, a senior developer with cloud admin access, cloned hundreds of GitHub repositories and exfiltrated substantial data from Ubiquiti's AWS infrastructure using his own administrative credentials. He then posed as an anonymous external attacker, sent a ransom demand for approximately $1.9 million in Bitcoin, and simultaneously acted as a "whistleblower" to journalists, claiming the breach was more severe than Ubiquiti disclosed — while participating in Ubiquiti's internal incident response as a senior employee. He was sentenced to six years in federal prison. [Documented — DOJ press release, criminal complaint]

Signals present in retrospect: AWS CloudTrail recorded the mass repository cloning and infrastructure access under Sharp's own credentials. A commercial VPN (Surfshark) masked the source IP during most activity. The ransom demand and the whistleblower communications followed immediately after the data access. [Documented — criminal complaint]

What triggered detection: During a home internet outage, Sharp's VPN connection dropped while he continued working. His residential IP was logged in CloudTrail for a brief unmasked window, linking the activity to his home address. [Documented — DOJ press release]

Key detection lesson: [Documented — DOJ criminal complaint] CloudTrail logs contained the full evidence trail throughout the incident. The actor was identified not by monitoring but by an operational security failure on his own part. [Inferred] Mass repository cloning and high-volume administrative AWS API activity under a single admin identity should trigger a real-time alert independent of source IP. The case also illustrates the risk of an insider participating in their own incident response.

3.10 Volodymyr Kvashuk — Microsoft Software Engineer (2018–2019)

Category: Financial fraud | **Organisation:** Microsoft

Kvashuk, a software engineer with access to Microsoft's testing environment, stole approximately $10 million in digital gift cards by abusing test-account access to generate and redeem them at scale. He used coworkers' credentials to mask his activity, routed proceeds through Bitcoin mixing services, and misrepresented the Bitcoin proceeds as a family gift on a mortgage application. He was sentenced to nine years in federal prison. [Documented — DOJ press release; Ninth Circuit opinion, US v. Kvashuk]

Signals present in retrospect: Test-account misuse for production financial operations. Anomalous gift-card generation and redemption velocity. Activity appearing under coworkers' credentials with patterns inconsistent with those accounts' normal use. Bitcoin monetisation of substantial value. [Documented]

What was missed: Separation of duties between test-environment access and production financial workflows. Monitoring of gift-card generation and redemption velocity anomalies. Identity correlation to detect activity inconsistent with the nominal account owner's historical pattern. [Inferred from documented facts]

What triggered detection: Microsoft detected unusual gift-card redemption activity and referred the matter to law enforcement. [Documented]

Key detection lesson: [Inferred] Financial fraud by a technical insider exploiting production-adjacent test access is a separation-of-duties problem first and a monitoring problem second. Anomalous financial operation velocity and cross-account identity inconsistency are the detectable signals.

3.11 Desjardins Group — Employee Data Theft (2017–2019)

Category: Data exfiltration / downstream fraud | **Organisation:** Desjardins Group (Canada)

Over at least 26 months, a malicious employee copied sensitive personal information — names, addresses, birth dates, social insurance numbers, email addresses, and financial data — from a marketing shared drive to

a work computer and then to USB keys. The data was shared with criminal organisations for downstream fraud. Approximately 4.2 million current members and approximately 173,000 former members and business members were affected. The Office of the Privacy Commissioner of Canada found Desjardins' controls insufficient on multiple dimensions and issued a remediation order. [Documented — OPC PIPEDA Investigation Report 2020-001]

Signals present in retrospect: Access to a shared drive containing data beyond the employee's normal scope. Repeated endpoint copies of sensitive files. Removable media writes over an extended period. Transfers consistently below volume thresholds that would have triggered automated controls. [Documented — OPC findings]

What was missed: Active monitoring was absent. DLP deployment was partial. UEBA was not deployed. Transfer controls were threshold-based and size-based, not sensitivity-based — sub-threshold transfers of highly sensitive regulated data were not flagged. Role-scope controls did not prevent access to data outside the employee's function. [Documented — OPC remediation requirements]

What triggered detection: The Laval police notified Desjardins during a separate criminal investigation. Internal controls detected nothing over 26 months. [Documented]

Key detection lesson: [Documented — OPC PIPEDA Investigation 2020-001] The OPC findings are the most explicit regulatory documentation of threshold-based DLP failure in this case set. The regulator's remediation order explicitly required controls covering transfers below the minimum volume threshold, as well as SIEM and UEBA deployment. [Inferred] Sensitivity-aware controls — triggering review on any movement of regulated data regardless of volume — directly address the failure mode documented in the OPC findings.

3.12 Tesla — Departing Employee Data Leak (2023)

Category: Departing employee / data exfiltration | **Organisation:** Tesla

Two former Tesla employees leaked approximately 100 GB of confidential data — including personal data on approximately 75,000 current and former employees, customer financial information, and production details — to the German newspaper Handelsblatt. Tesla attributed the disclosure to departing employees and pursued legal action. [Documented — Tesla legal filings; Handelsblatt reporting]

Signals present in retrospect: Large-scale data export by employees in the departure window. Data included HR records and production data outside the employees' functional scope. 100 GB is a high-signal volume event in any access log. [Documented]

What triggered detection: Handelsblatt contacted Tesla before publication. Tesla's investigation identified the former employees via access logs. [Documented]

Key detection lesson: [Documented — CERT/CMU [4]] CERT data indicates that in studied IP-theft cases, the last-confirmed harmful act occurred disproportionately in the period leading up to or shortly following departure. The exact percentage varies across CERT study cohorts and editions; consult [4] for the most current figure. [Inferred] Volume monitoring on data exports should be specifically heightened during the departure window. Access to data outside current role scope during this window should generate alerts regardless of volume.

3.13 Twitter — Saudi Arabia State-Sponsored Insider Espionage (2015)

Category: Insider espionage / state-sponsored collusion | **Organisation:** Twitter

Ahmad Abouammo (a former media partnerships manager) and Ali Alzabarah (a former site reliability engineer) used internal Twitter user-information tools to retrieve private account details — including phone numbers and IP addresses — belonging to Saudi dissidents and government critics, and passed the information to Saudi intelligence officials. Alzabarah accessed data associated with more than 6,000 Twitter accounts on a single day. Abouammo received a watch and monetary payments; Alzabarah received gifts and a payment. Abouammo was convicted at trial; Alzabarah fled to Saudi Arabia before arrest. [Documented — DOJ criminal complaint; verdict in US v. Abouammo]

Signals present in retrospect: High-volume sensitive account lookups with no business justification. Access to accounts belonging to individuals of political significance to a specific foreign government. Unusual communication with individuals connected to foreign state actors. [Documented — complaint]

What was missed: Purpose-binding and access controls on the user-information tools. Alerting on high-risk profile access (politically sensitive accounts, journalists, activists). Count-based anomaly detection — accessing more than 6,000 accounts in a single day is a high-signal volumetric event regardless of role. [Inferred from documented facts]

What triggered detection: Twitter management confronted Alzabarah after observing one suspicious access. He fled the country the following day. The FBI investigation followed. [Documented]

Key detection lesson: [Documented — DOJ criminal complaint [17]] The access tool existed; alerting on its abuse did not. [Inferred] A daily count threshold on user-information tool queries would have flagged the 6,000-account single-day access pattern. Access to sensitive data categories (journalist and activist accounts) requires purpose-binding controls regardless of the employee's role.

3.14 Juliana Barile — Former New York Credit Union Employee (2021)

Category: Sabotage / post-termination destructive access | **Organisation:** New York credit union (unnamed in public record)

Barile, a former employee at a New York credit union, was terminated on 19 May 2021. Her remote access credentials were not revoked at the time of departure. Two days after termination, on 21 May 2021, she remotely accessed the credit union's file servers without authorisation and deleted approximately 21.3 GB of data — approximately 20,000 files and 3,500 directories — in apparent retaliation. She was charged in June 2021 with intentional damage to a protected computer under the Computer Fraud and Abuse Act (18 U.S.C. § 1030(a)(5)(A)) and subsequently pleaded guilty. [Documented — DOJ USAO SDNY press release, June 2021 [18]]

Signals present in retrospect: Post-termination remote authentication using credentials that should have been revoked at departure. Bulk file deletion at scale — 20,000 files and 3,500 directories in a single session — visible in file server and VPN access logs. Temporal pattern: access occurred 48 hours after documented termination date. [Documented — DOJ press release [18]]

What was missed: Credentials not revoked on termination. No alerting on authentication by a departed employee's account. No real-time alerting on bulk deletion volume in that session. [Inferred from documented facts]

What triggered detection: The data loss itself — the credit union discovered the deletion after the fact. Technical controls did not detect the access in real time. [Documented]

Key detection lesson: [Inferred] This case follows the same structural failure as Cisco/Ramesh (§3.5): credentials not revoked at departure are an open door. Two independent alerting opportunities existed in real time — a post-termination account authentication and a mass deletion event in the same session — and neither was monitored. The detection gap was not a signal-availability problem; it was a programme-deployment problem. Both signals (post-termination auth, bulk deletion threshold) are Tier 1 controls requiring no machine learning or baseline periods.

3.15 CERT Financial Fraud Operational Patterns

Category: Financial fraud | **Source:** CERT/CMU Common Sense Guide to Mitigating Insider Threats, 7th Ed. [4]

CERT's case database documents recurring fraud patterns in the financial and broader commercial sector:

- Accounts payable employees creating ghost vendors with personal bank account numbers
- Same employee creating and approving transactions (segregation-of-duties violation)
- Legitimate vendor payment detail modified to redirect funds to insider-controlled accounts
- Transactions structured just below approval thresholds
- Activity concentrated outside business hours or during holiday and audit periods
- Ghost employees on payroll with deposits to insider-controlled accounts

CERT's banking-and-finance sector study found that 61% of cases were detected by non-security personnel, 22% by auditing or monitoring, and logs were used for attribution in 74% of cases where the insider's identity was established. [Documented — CERT/CMU]

Key detection lesson: [Inferred from CERT case patterns [4]] Financial fraud detection is primarily a business process control problem — segregation of duties, dual approval, payment integrity verification — not a network or endpoint security problem. SIEM-based detection for this category requires integration with ERP audit logs (SAP, Oracle, Workday) and transaction metadata, not just authentication events.

---

4. Detection Methods

The detection logic below is defender-operable guidance. Where logic is directly supported by a documented case or primary source, it is cited. Where the correlation is an engineering synthesis, it is marked **[Inferred]**. Windows Event IDs listed below are standard audit policy outputs; they require correct audit policy configuration and are not produced by default on all systems. Validate all event IDs and M365 operation names in your environment — audit policy settings, licence tier, and tenant configuration affect what is actually generated. Specific thresholds listed are illustrative starting points; production values must be calibrated to your environment.

4.1 Deterministic Rules

These rules fire on specific artefact patterns with near-zero legitimate prevalence in a properly configured environment. They require no baseline period and produce the highest signal-to-noise ratio available for this problem class. Deploy these first.

Post-termination access attempts

Catches any authentication or resource access by an account belonging to a terminated or resigned employee or contractor whose engagement has ended.

Log source: IdP sign-in logs (Entra ID, Okta, ADFS); VPN authentication logs; AWS CloudTrail `ConsoleLogin` and `AssumeRole`; AD Event 4624 / 4625 on domain controllers.

Detection logic: Maintain a terminated-accounts list fed from HR; alert on any successful or failed authentication by an account on that list. Successful post-termination authentication should be treated as an incident until documented otherwise. [Inferred — operationalisation of documented case pattern]

False positives: Service accounts shared with departed users; accounts not yet fully deprovisioned due to HR-feed lag.

Real case: Cisco/Ramesh — AWS credentials used 5 months after resignation to delete 456 VMs. CloudTrail evidence was present; no real-time alert existed. [Documented]

Prerequisite: HR system integration with identity management; accounts disabled within a defined SLA of departure (same business day is the recommended target).

Audit log deletion or disablement

Catches covering-tracks activity: clearing Windows Event Logs, disabling cloud audit trails, or stopping log forwarding agents.

Log source: Windows Security Event 1102 ("The audit log was cleared" — Security channel); Microsoft-Windows-Eventlog/Operational Event 104 (non-Security log cleared, e.g., System, Application); AWS CloudTrail `StopLogging`, `DeleteTrail`; Azure Diagnostic Settings deletion or Log Analytics workspace deletion; SIEM ingestion health monitoring for unexpected log-source silence.

Detection logic: Alert on any occurrence of Security/1102 or Eventlog/Operational/104 outside a documented maintenance window. Alert on any `StopLogging` or `DeleteTrail` API call — these have near-zero legitimate ad-hoc prevalence on production infrastructure. Alert when a monitored critical log source stops producing events for longer than your expected collection latency (15 minutes is a commonly used illustrative threshold; calibrate to your pipeline's actual latency characteristics). [Inferred] Log clearing should generate an immediate incident ticket, not a risk score increment within a UEBA framework. It should not be handled via threshold accumulation.

False positives: System reimaging, approved maintenance. Require change ticket correlation to suppress.

Real cases: Waymo/Levandowski — laptop reformatted during notice window. Yahoo/Ruiz — computer and hard drive destroyed after detection. These were post-primary-act cover-up actions; detecting them early provides a second detection opportunity. [Documented — case records]

Email forwarding rule to external address

Catches inbox rules forwarding all or selected email to a personal external account — a pre-departure intelligence gathering or sustained low-friction exfiltration technique.

Log source: Exchange / Microsoft 365 Unified Audit Log operation `New-InboxRule` (where `ForwardTo` or `RedirectTo` contains an external domain); `Set-Mailbox` with `ForwardingAddress` or `ForwardingSmtpAddress` set to a non-corporate domain. Note: the exact operation names available depend on M365 licence tier and audit configuration — validate against your UAL before deployment.

Detection logic: Alert on any inbox rule or mailbox-level forwarding setting that directs mail to a non-corporate domain, when created by a non-IT account. Review any rule created during a departure notification window immediately. [Inferred]

False positives: Low in organisations with enforced acceptable use policies. Legitimate delegated routing should be IT-managed, not user-created.

Bulk file copy to removable media

Catches USB drives, SD cards, or external hard disks used to stage files for physical exfiltration.

Log source: Windows Security Event 4663 (object access, with SACL configured on sensitive directory paths) correlated with a removable volume path; DLP endpoint agent removable media events; Sysmon Event 11 (FileCreate) where the target path is a removable volume; Windows Event 6416 (new external device recognised by the system).

> ***Operational warning — Event 4663 EPS/ingestion cost****: Enabling object access auditing (Event 4663) for file reads on general file shares will immediately destroy a SOC's EPS budget. On a typical enterprise file server handling thousands of concurrent sessions, read-access events generate tens of thousands to hundreds of thousands of events per minute. In SIEM platforms priced by EPS (such as*

> *IBM QRadar) this directly translates to licence overrun; in consumption-based platforms (such as Google SecOps / Chronicle) it creates immediate ingestion cost spikes.* ***SACLs for read auditing must be scoped exclusively to crown-jewel directory paths*** *— specific directories containing classified data, source code, financial records, or regulated HR data. Write and delete auditing (Events 4660 and 4663 for write/delete operations) generate substantially lower event volumes and can be deployed more broadly, but still require deliberate SACL scoping rather than share-root application.*

Detection logic: Alert on file writes to a removable volume by a non-IT user account; escalate when: (a) source files originate from monitored sensitive paths, (b) file count exceeds a threshold in the session (calibrate per role — a starting point is >50 files), or (c) the user is in a departure window flagged by HR. [Inferred]

False positives: IT imaging, authorised offline backup. A device control policy that blocks unauthorised USB by default reduces false positives substantially — the alert then fires only for authorised devices with unusual activity patterns.

Real cases: Manning — writable CD used on SIPRNet with no removable media DLP. Levandowski — removable media connected for an extended period during the notice window. Desjardins — USB keys used repeatedly over 26 months. [Documented — case records]

Compression of sensitive directories

Catches data staging — an actor archiving files prior to exfiltration. Compression frequently precedes bulk data movement.

Log source: Sysmon Event 1 / Windows Security Event 4688 with command-line logging enabled: process names `7z.exe`, `7za.exe`, `winrar.exe`, `zip.exe`, and PowerShell `Compress-Archive` with source path arguments pointing to monitored directories.

Detection logic: Alert when an archiving utility is executed by a user-interactive session where the source path argument includes sensitive directories (HR, Finance, Legal, source code, IP-classified paths). Combine with a subsequent upload or removable media write for higher confidence. [Inferred]

False positives: Legitimate backup processes and developer packaging. Mitigate by scoping to user-interactive sessions rather than backup service accounts.

Large SharePoint or repository download

Catches "repository drain" — large-scale file download from document stores, SharePoint sites, or source code repositories.

Log source: Microsoft 365 UAL operations `FileDownloaded`, `FileSyncDownloadedFull`; GitHub audit log repository clone events; GitLab clone API events; Confluence space export audit. Note: `FolderDownloaded` is not a confirmed standard M365 UAL operation — validate the exact operation names available in your tenant, as they vary by workload, licence tier, and client type.

Detection logic: Alert when a user's daily download event count from SharePoint or OneDrive exceeds their 30-day rolling average by a material threshold. Additionally, alert on any single-session bulk download exceeding a fixed count threshold (e.g., >500 files) by a non-IT account. Specific thresholds are illustrative and require environment calibration. [Inferred]

> ***Operational warning — Z-score and right-skewed distributions****: A Z-score ≥ 3 is a commonly cited starting point, but it is mathematically flawed as a standalone threshold for file download counts. Human file-access and download counts are right-skewed, not normally distributed: a small number of power users (developers, data engineers, project leads) generate dramatically higher volumes than the median user. Applying an untransformed Z-score will simultaneously under-alert on power users (whose baseline absorbs large spikes) and over-alert on low-volume users (whose small increase registers as a large standard-deviation event).* ***Before deploying Z-score alerting, log-transform the download counts or use percentile-based thresholds calibrated per role cluster.*** *Validate that your threshold produces acceptable alert rates across all role cohorts, not just the median user, before enabling automated queue entries.*
>
> ***Operational warning — OneDrive/SharePoint sync client false positive****: When a user provisions a new device, the OneDrive or SharePoint sync client performs a full library resync, generating a burst of `FileDownloaded` and `FileSyncDownloadedFull` events that is volumetrically identical to a repository drain by a malicious actor. A SOC that does not filter automated sync user-agents before enabling download-volume alerting will experience immediate and sustained alert fatigue from this false positive.* ***Filter events where the `UserAgent` field contains known sync client identifiers*** *(e.g., `OneDriveMpc-Transform_Sync`, `Microsoft SkyDriveSync`, or equivalent strings for your client version) prior to applying volume thresholds. Consider excluding `FileSyncDownloadedFull` events that are not correlated with any human-interaction signals in the same session.*

False positives: Legal discovery runs, project migrations, DR tests, and new device provisioning (see sync client warning above). Require change tickets for large-scale movements to suppress false positives.

Screenshot and screen capture tool execution

Catches capture of data that cannot be exfiltrated via file copy — an employee on a DLP-protected terminal capturing screen content to bypass file-movement controls.

Log source: Sysmon Event 1 / Event 4688 with command-line: `SnippingTool.exe`, `ScreenSketch.exe`, `ShareX.exe`, `Greenshot.exe`, `PSR.exe` (Problem Steps Recorder).

Detection logic: Alert when screen capture tool execution is correlated within a configurable time window with concurrent access to a monitored sensitive directory path. Standalone first-execution alerting on screen capture tools is impractical on most endpoint populations: SnippingTool.exe and ScreenSketch.exe ship with Windows and have significant organic usage that will generate high false-positive volumes without the sensitive-directory correlation as a primary condition. Alert on high-frequency screen capture tool execution during repository access sessions. [Inferred]

False positives: Support desk documentation, training materials. Allowlist expected tools on designated support workstations.

4.2 Behavioural Heuristics

These detections require a baseline period (typically 30–90 days) and produce more false positives than deterministic rules. They are essential for catching "authorised but abnormal" behaviour that deterministic rules cannot reach. Tune against your environment before enabling automated alerting.

After-hours access

Catches activity outside the user's established working-hours baseline.

Log source: IdP sign-in timestamps; file server access timestamps; SaaS audit log timestamps; EDR process execution timestamps; badge-access records (correlate with digital access where available).

Detection logic: Establish a per-user working-hours baseline over a 30–90 day rolling window. Alert when activity occurs materially outside the user's normal distribution AND is combined with at least one identity-

context signal: impossible travel, access from an unmanaged or non-compliant device, conditional access policy failure, MFA anomaly, sensitive resource access, bulk data volume, departure status, or privilege use. Time-of-day alone is a weak signal and must not be used as a standalone alert trigger. [Inferred]

False positives: International travel, time zone changes, on-call rotations, global teams. Correlate with HR calendar to reduce.

Note: In modern asynchronous remote-work environments, time-of-day has become a near-dead standalone signal. An organisation with employees across time zones, flexible work arrangements, or work-from-home policies will have significant legitimate after-hours activity across every cohort. Standalone temporal deviation, even when combined with sensitive resource access, generates high false-positive rates in these environments. After-hours alerting must be paired with identity-context signals to produce actionable alerts; without that pairing it belongs in Tier 3, not Tier 2. [Inferred]

Note: Sophisticated, planned insiders deliberately operate within their own normal working hours to evade temporal detection. After-hours detection has higher value for reactive and opportunistic actors. [Inferred]

Access outside role scope

Catches users accessing data, systems, or applications that their peer cohort never or rarely accesses.

Log source: File server access logs (Event 4663 with SACL); SharePoint site audit logs; CRM and ticketing system audit logs; ERP audit logs; database access logs.

> ***Operational warning — Event 4663 EPS/ingestion cost****: See the same warning under §4.1 Bulk file copy. The ingestion-budget risk applies here as well: SACLs enabling read-access auditing on broad file share paths will generate unmanageable event volumes in any SIEM deployment. Scope Event 4663 read auditing to crown-jewel paths only. For role-scope detection on general shares, rely on SharePoint site audit logs, CASB, and application-layer audit trails rather than file-system read events.*

Detection logic: Build access frequency profiles per resource path per role group. Alert when a user accesses a resource with zero or near-zero access frequency among their peer group, particularly when the access is high-volume, involves sensitive data, or lacks an open ticket or business purpose. [Inferred]

False positives: Cross-functional project assignments, temporary role expansions. Mitigate with a documented exception workflow.

Real cases: Snowden — sysadmin files outside operational assignment. Yahoo/Ruiz — user-data access with no business purpose or ticket. Twitter/Saudi Arabia — account lookups on politically sensitive profiles with no operational context. [Documented — case records]

Peer-group deviation

Catches users who remain within formally authorised systems but behave in ways that differ materially from colleagues in the same role.

Log source: Identity metadata (department, title, team, project assignments); application access logs; file, email, and web activity telemetry.

Detection logic: Cluster users by role, department, and seniority. Compute a deviation score comparing individual behaviour against the cluster centroid across: resource access diversity, data volume, application mix, time-of-day distribution, and external communication volume. Alert when a user's deviation score places them in the top 1–2% of their cluster, particularly when combined with an HR risk or departure flag. [Inferred]

Research context: Academic work using the CERT Insider Threat Synthetic Dataset (CMU-CERT r4.2–r6.2) has explored peer-group and role-aware approaches. No specific performance figures from that research are cited here, as those datasets are synthetic and limited in scale; benchmark results from synthetic datasets should not be taken as production performance guarantees. Production results require independent validation on real enterprise telemetry. [Inferred from published research direction; no specific paper is cited]

False positives: Heterogeneous peer groups, stale role metadata. Review cluster composition quarterly.

Data staging pattern (composite)

Catches the sequence of collection → archiving → external transfer or removable media write.

Log source: Process creation logs; file creation and rename logs; repository read logs; DLP events; removable media events; network/SaaS egress logs.

Detection logic: Within a configurable time window, look for: (1) access to monitored sensitive paths, followed by (2) archive utility execution with a sensitive source path, followed by (3) file write to removable media, upload to personal cloud, or email to external address. Require at least two of the three post-access steps for alert generation. Time window values are environment-dependent. [Inferred]

False positives: Legitimate packaging and handoff workflows. Scope step (1) to monitored sensitive path classes to reduce noise.

Real cases: Levandowski — repository access followed by extended removable media attachment. Desjardins — shared-drive to endpoint to USB pipeline. Manning — SIPRNet download followed by CD-RW write. [Documented — case records]

Departing employee volume spike

Catches bulk data staging in the departure window, which CERT data consistently identifies as the highest-risk period across IP-theft cases [4]. The exact percentage varies across CERT study cohorts and editions; consult [4] for the most current figure.

Log source: HR departure date flag (must reach SIEM within hours of resignation); download event counts; DLP events; removable media events; first-time repository access events.

Detection logic: When HR flags a departure: (a) enrol the user in a departure watchlist, (b) lower anomaly thresholds for data movement alerts, (c) alert on any combination of: download volume increase materially above 90-day average, first-time access to data outside current role, archive creation on sensitive paths, or upload to personal cloud. Specific threshold multipliers require environment calibration. [Inferred]

False positives: Legitimate handover documentation. Require manager approval for large data transfers during offboarding.

Real cases: Levandowski — departure window data staging. Tesla 2023 — 100 GB export by departing employees. [Documented — case records]

Access velocity anomaly

Catches users accessing hundreds of unique files in a short period — staging behaviour inconsistent with normal reading or working speed.

Log source: File server audit Event 4663; SharePoint `FileDownloaded` and `FileAccessed` events.

Detection logic: Alert when a user's unique file access count in a rolling 60-minute window exceeds a threshold inconsistent with normal human workflow. A starting point for knowledge workers might be >200 unique files per hour, but this must be calibrated per role and environment. Scope to interactive sessions to reduce automation false positives. [Inferred]

Print-volume spikes

Catches conversion of digital data to paper — bypassing all digital file-movement controls.

Log source: Microsoft-Windows-PrintService/Operational Event 307 ("A document was printed" — includes user, printer, document name, page count, job size); DLP print channel monitor; network print server audit logs.

Detection logic: Note: PrintService/Operational log forwarding requires deliberate configuration in most SIEM deployments and is not present by default. Volume-based anomaly alerting on printing requires a per-user, per-application 90-day baseline. False-positive volume is high during business cycle peaks (board packs, financial close, audit preparation). This detection is Tier 2, not Tier 1, despite its appearance in many reference guides. Alert when a user's daily page count from sensitive applications (HR systems, financial platforms, source code viewers) exceeds their 90-day rolling average by a meaningful multiple. Alert on printing of documents matching DLP classification labels. Specific multiplier thresholds are environment-dependent. [Inferred]

False positives: Board packs, financial close, audit preparation packages. Calibrate per business cycle.

Note: The print vector is under-represented in publicly documented prosecution records. This reflects investigative limitations, not low prevalence. [Inferred]

4.3 Identity and Privilege Anomalies

New admin account creation outside change windows

Catches insider creation of backdoor administrative accounts.

Log source: Windows Security Event 4720 (user account created); Events 4728, 4732, 4756 (member added to security-enabled group — domain-global, local, universal respectively); Azure AD / Entra audit log "Add member to role"; AWS IAM `CreateUser`, `AttachUserPolicy`, `CreateAccessKey`.

Detection logic: Alert on any privileged account creation — account added to Domain Admins, local Administrators, or a cloud admin role — where the creating account is not a known IT provisioning service account and the event time falls outside an approved change window. This event has near-zero legitimate prevalence for non-IT accounts. [Inferred]

False positives: Emergency break-glass procedures, mitigated by pre-approved emergency workflows with out-of-band notification.

Access to high-sensitivity systems with no prior history

Catches first-ever authentication to crown-jewel systems by a user who has never previously accessed them.

Log source: Windows Security Event 4624 (Logon Type 3 = network, Type 10 = remote interactive) on target systems; PAM session initiation logs; cloud service access logs.

Detection logic: Maintain a per-user access history (user → set of systems previously authenticated to). Alert on first-ever authentication to a high-sensitivity tier (domain controller, database server, payment processing system, backup infrastructure) when combined with data volume or an active HR risk flag. [Inferred]

False positives: New system deployments, role changes. Apply a short grace period (e.g., 72 hours) tied to documented role-change events.

Access during leave or announced departure

Catches an account active during a period when HR records indicate the user is on leave, suspended, or departed.

Log source: IdP sign-in logs correlated with HR calendar data; leave management system integration.

Detection logic: Alert on any authentication by an account where HR records the user as inactive (on leave, suspended, or terminated). Near-zero false positives when HR data is current. [Inferred]

Access creep detection

Catches users retaining entitlements from previous roles, creating unintended high-privilege combinations.

Log source: IAM / AD group membership audit logs; SaaS application access provisioning logs; periodic entitlement snapshot comparison.

Detection logic: Weekly comparison of each user's effective permissions against their current role baseline. Alert when effective access includes resource classes not associated with the current documented role. Flag accounts that have changed roles without a corresponding access review. [Inferred]

Real case: Desjardins — the insider accessed data in the banking warehouse that was not required for their marketing function, enabled by weak role segmentation. [Documented — OPC findings]

Lateral movement with valid credentials

Catches an insider (or external attacker using insider credentials) pivoting between systems using real accounts.

Log source: Windows Security Event 4624 (Type 3 network logon) across multiple target systems; remote execution events (WMI, WinRM, PsExec, SSH); PAM session logs.

Detection logic: Correlate a user identity appearing on multiple new hosts in rapid succession — more than a handful of new hosts in a short window outside a documented maintenance window — especially when paired with admin tool execution. Specific count and time window thresholds must be calibrated per environment and role. [Inferred]

False positives: IT support engineers, automation scripts. Scope to non-automation accounts and correlate with change tickets.

4.4 Exfiltration Path Coverage

A complete programme must monitor all meaningful exfiltration channels. Email DLP is a common starting point, but the case evidence shows most documented exfiltrations used channels other than email as the primary path.

Email to personal domain. Monitor: Exchange UAL `Send` operation (the M365 UAL operation for messages sent by the mailbox owner — verify the exact operation name in your tenant, as it varies by client and licence) where recipient domain is a consumer provider, combined with attachment size threshold or DLP classification match. Key signal: sensitive attachment to personal domain, volume spikes, departure flag. Primary limitation: steganography and encryption are undetectable by content-based DLP, as demonstrated in the GE/Zheng case over an extended period. Behavioural controls (volume, domain, attachment frequency) are effective where content controls are not. [Documented — case record]

USB and removable media. See §4.1 for log sources and logic. Primary limitation: hardware-level physical capture (photographing a screen) produces no digital artefact and has no technical detection solution.

Personal cloud sync (Dropbox, Google Drive, personal OneDrive, iCloud Drive). Monitor: CASB or web proxy for "Personal Cloud Storage" category with user identity attribution; endpoint DLP sync-client network connections. Key signal: upload to personal cloud storage from a corporate device or managed network. Primary limitation: HTTPS inspection required for URL-level visibility; mobile hotspot bypasses corporate proxy entirely. [Inferred]

SaaS upload (Slack, GitHub, Jira, Confluence). Monitor: SaaS audit logs for file upload and attachment operations; CASB file upload events; GitHub personal access token creation and clone events; OAuth grant events. Key signal: volume of uploads deviating from peer baseline; new OAuth grants to unrecognised applications; long-lived personal access token creation. Primary limitation: SaaS platforms with limited or no native file-operation audit logging; abuse of existing approved integrations. [Inferred]

Printing. See §4.2 for log sources and logic. Primary limitation: physical capture of printed output has no technical detection.

Screen capture tools. See §4.1. Primary limitation: a personal phone aimed at a monitor has no technical detection solution.

Covert channels and low-and-slow exfiltration. Monitor: DNS resolver logs for high-entropy subdomain labels (DNS tunnelling); Zeek dns.log for TXT query volume and unusual query lengths; proxy logs for periodic low-volume outbound connections to consistent external destinations. Key signal: persistent, periodic outbound connections to a fixed external destination correlated with prior sensitive data access. Primary limitation: low-entropy encoding (as used in the SUNBURST C2 channel) evades entropy-based detection [24]. The Desjardins case shows the primary problem is threshold blindness: sub-threshold transfers over months are undetectable without sensitivity-aware or correlation-based controls. [Documented — OPC findings]

4.5 Sabotage Signals

Sabotage detection requires monitoring of control-plane actions separately from standard data access monitoring. Standard email and file-access DLP does not cover this threat category.

Mass deletion event. Catches bulk deletion of VMs, repository contents, S3 objects, database records, or file server directories. Log source: AWS CloudTrail `TerminateInstances`, `DeleteBucket`, `DeleteObject` at bulk scale; Azure Activity Log VM deletion events; File server audit Event 4660

correlated with Event 4663 at high volume; database audit `DROP TABLE` / unqualified `DELETE`. Detection logic: alert when deletion operation count from a single identity exceeds a threshold within a defined window — specific values must be calibrated per role and environment. [Inferred] Real case: Cisco/Ramesh — 456 VMs deleted in a concentrated burst visible in CloudTrail. [Documented]

Backup deletion and recovery-denial. Catches deletion of backup objects, VSS shadow copies, or disabling of backup policies. Log source: Backup system logs; AWS `DeleteBackup`, `DeleteRecoveryPoint`; Azure Backup vault deletion events; Sysmon Event 1 with command-line `vssadmin delete shadows`, `wmic shadowcopy delete`, `bcdedit /set recoveryenabled no`. Detection logic: alert on any backup deletion by a non-backup-admin account outside a documented change window — this has near-zero legitimate ad-hoc prevalence. [Inferred]

Logic bomb artefacts. Catches delayed destructive code planted in scheduled tasks, WMI subscriptions, or cron jobs. Log source: Windows Security Event 4698 (scheduled task created); Microsoft-Windows-WMI-Activity/Operational Event 5861 (new permanent WMI subscription); Linux auditd crontab modification events. Note: Events 4698 and 5861 are Windows Security and WMI-Activity events respectively — they are NOT Sysmon events. Detection logic: alert on any new scheduled task or WMI subscription created by a non-IT account or outside a documented change window, particularly where the consumer executes a script from a user-writeable path. [Inferred] Real case: UBS/Duronio. [Documented]

CI/CD pipeline tampering. Catches modification of build, release, or deployment pipeline configurations. Log source: source-control audit for commit author, branch, and changed file paths; branch protection rule modification events; pipeline definition change events (GitHub Actions, GitLab CI, Jenkins). Detection logic: alert on direct commits to a protected branch by accounts that normally work on feature branches; alert on changes to pipeline workflow files by non-pipeline-owner accounts; alert on pipeline configuration changes outside approved change windows. [Inferred]

Configuration changes outside change windows. Catches sabotage preparation, firewall modification, or stealth privilege expansion. Log source: CMDB and change calendar integration; infrastructure-as-code repository commit audit; cloud security group and IAM policy modification events; firewall syslog. Detection logic: alert when a privileged user modifies production configuration — firewall rules, GPO, IAM policies, DNS records — without an associated open change ticket. [Inferred]

4.6 UEBA and Anomaly Models

UEBA addresses the "authorised but anomalous" problem that deterministic rules cannot reach. Its value is not in replacing deterministic rules but in providing a corroborating risk layer that requires multiple weak signals

to converge before generating an analyst alert.

Entity risk scoring

The most practical bridge between deterministic rules and full ML-based UEBA. Aggregates multiple weak signals into a per-user risk score over a rolling time window.

Each signal should be assigned an ordinal risk tier — LOW, MEDIUM, HIGH, or CRITICAL — based on its prevalence in your environment and its correlation with documented insider behaviour. Treat LOW signals as corroborating evidence only; treat HIGH signals as sufficient to open analyst review when combined with two or more LOW or MEDIUM signals; treat CRITICAL signals as requiring immediate incident response independent of any accumulated score. Representative tier assignments (calibrate before deployment): after-hours access to sensitive resources [LOW]; peer-group deviation in top percentile [LOW]; first-time access to a high-sensitivity system [MEDIUM]; repository download volume materially above baseline [MEDIUM]; removable media write from a sensitive path [HIGH]; email forwarding rule to external domain [HIGH]; HR departure flag active [HIGH]. Remove log clearing from this risk-scoring framework entirely — see §4.7 and §4.1 for log clearing as a deterministic incident trigger.

Score decay: reduce scores that are not reinforced within a defined window (e.g., 7 days). The score should reflect current risk trajectory, not historical events. [Inferred — general UEBA design principle]

Commercial platforms implementing this approach include Microsoft Purview Insider Risk Management, Exabeam, Securonix, Varonis Data Security Platform, and Splunk Enterprise Security (with integrated UEBA capabilities). Capabilities differ across platforms; evaluate against your specific telemetry sources.

Limitation: Risk scores require a baseline period (typically 30 days). New and transferred employees generate cold-start false positives. HR role context is essential for suppressing noise — scores without role integration produce unacceptable false-positive rates in most environments.

Regulatory validation: The OPC's Desjardins findings explicitly identified SIEM and UEBA as active-surveillance tools that would have generated alerts on the insider's behaviour, and required both as remediation items. [Documented — OPC PIPEDA 2020-001]

Peer-group clustering

Calibrates anomaly scoring to realistic "normal" for each role rather than the whole organisation.

Implementation: cluster users by department, job title, seniority band, and access tier. Compute per-user deviation scores relative to the cluster centroid. Alert on users placing in the top percentile of their cluster by deviation score, particularly when combined with an HR or departure flag.

Research context: See the note on CERT Insider Threat Synthetic Dataset research in §4.2. Academic peer-group approaches show promise on benchmark evaluations; real-world production results require independent validation. These are appropriate as a Tier 3–4 programme capability, not a day-one deployment.

Sequence anomaly models

Detect ordered action chains: authenticate → access new system → read sensitive files → create archive → exfiltrate.

Implementation: model expected action sequences per role class using Markov chains (lower implementation complexity) or LSTM/transformer models (higher recall potential, greater training data requirement). Flag sequences deviating from the learned model for the role class. Focus on the access → archive → external transfer three-step sequence. [Inferred]

Research context: Academic LSTM and transformer-based approaches on CMU CERT synthetic datasets show measurable performance improvement over simpler baselines in controlled evaluations. Those datasets are synthetic and do not reflect real enterprise heterogeneity. Treat these models as a mature programme capability (Tier 4), not a general-availability default. Real-world production deployment requires significant feature engineering, labelled data from your own environment, and ongoing maintenance.

Graph analytics on access patterns

Represent users, systems, and data repositories as nodes; access events as edges. Anomalous behaviour appears as new edges connecting a user to previously unvisited high-sensitivity parts of the graph.

Implementation: track first-occurrence timestamps for each user-to-resource edge. Apply community detection to identify clusters of resources accessed together as part of normal workflows. Alert when a user accesses a resource outside their community — particularly when that resource is in a high-sensitivity tier. [Inferred]

Research context: Graph-based approaches to insider threat detection have been explored in academic settings. As with sequence models, treat this as a Tier 4 capability requiring specialised infrastructure, engineering resources, and ongoing model maintenance.

4.7 Covering-Tracks Detection

Covering-tracks activity typically occurs in Phase 6, after the primary harmful act. Detecting it provides a second detection opportunity, and the forensic trail preserved before covering-tracks activity completes often determines whether prosecution is viable.

Windows Event log clearing. Windows Security Event 1102 ("The audit log was cleared" — Security channel); Microsoft-Windows-Eventlog/Operational Event 104 (log cleared for System, Application, or other non-Security channels). Alert on any occurrence outside a documented decommission or gold-image rebuild. There is no legitimate automated process that clears the Security Event Log on a production system. Extend to cloud logging disablement: AWS `StopLogging`, `DeleteTrail`; Azure Diagnostic Settings deletion; GCP audit log sink deletion; SIEM forwarding agent silence.

Anti-forensic tool execution. Sysmon Event 1 / Event 4688 command-line: `sdelete.exe`, `cipher.exe /w`, `BleachBit.exe`, `Eraser.exe`, `secure-delete` or `shred` (Linux) on endpoints that also accessed sensitive repositories. Alert on execution of known secure-deletion tools outside a documented IT decommissioning workflow. Real cases: Yahoo/Ruiz — computer and hard drive destroyed post-detection. Levandowski — laptop reformatted during notice window. [Documented — case records]

PowerShell history deletion. Sysmon Event 23 (FileDelete, available from Sysmon v7.01 onwards) targeting `%APPDATA%\Microsoft\Windows\PowerShell\PSReadline\ConsoleHost_history.txt`; PowerShell Script Block Logging Event 4104 for execution of the `Clear-History` cmdlet (requires Script Block Logging enabled via Group Policy). Note: Sysmon Event 11 is FileCreate, not FileDelete — use Event 23 for file deletion detection. Alert on deletion of the history file or execution of `Clear-History`, particularly within a short window of sensitive operations. [Inferred]

File timestamp manipulation (timestomping). Sysmon Event 2 (FileCreateTime changed) — fires when any process programmatically modifies a file's CreationTime attribute. Alert on any Event 2 occurrence on files in sensitive directories or on archive files. Cross-reference with USN journal entries where available.

Linux audit trail manipulation. auditd configuration changes (`auditctl -e 0` disabling auditing); deletion or truncation of `/var/log/audit/audit.log`, `/var/log/auth.log`, `/var/log/secure`. Alert on any audit configuration change that reduces logging scope. Forward auditd logs to SIEM via a write-protected pipeline that host-level root access cannot modify — if audit logs exist only on the local host, a privileged insider can destroy the evidence trail entirely.

---

5. Detection Priority Matrix

Rated on implementation effort (licensing, configuration, integration complexity) and detection coverage (signal-to-noise ratio against the threat categories in §3), under realistic enterprise conditions.

Tier 1 — Deploy immediately (Low effort, High signal, Very low FP rate)

These rely on events already generated or requiring minor audit policy changes. They have near-zero false-positive rates in properly maintained environments. ROI is highest here.

- **Post-termination access alerting** — Requires HR→IdP feed. Catches departing employee and sabotage categories. Evidence: Cisco/Ramesh.
- **Audit log clearing alerting** — Security/1102 and Eventlog/Operational/104 are already generated; forward and alert.
- **Email forwarding rule to external domain** — M365 UAL already captures this event.
- **New privileged account creation** — AD Events 4720/4728/4732/4756 already generated on domain controllers.
- **Backup deletion outside change window** — Cloud backup and vault logs already generated.

Tier 2 — Deploy second (Medium effort, High value)

These require moderate configuration, baseline setup, or endpoint agent deployment.

- **Departing employee composite rule** — Requires HR departure date integration. Highest single ROI for IP theft category. FP rate: low when HR feed is timely.
- **Mass deletion alerting** — Requires cloud and file audit configuration; threshold calibration per role.
- **Bulk repository download anomaly** — Requires M365 UAL + 30-day per-user baseline; sync client user-agent filtering required before enablement (see §4.1 warning).
- **USB/removable media DLP** — Requires endpoint DLP agent deployment.
- **Logic bomb artefact detection** — Windows Security Event 4698 and WMI-Activity/Operational Event 5861; scope to non-IT accounts.

Tier 3 — Deploy third (Medium–High effort, High analytical value)

Require baseline periods, role taxonomy, or HR metadata integration.

- **Access outside role scope** — Requires role taxonomy and 30+ day access baseline. Medium FP rate; improves with accurate role data.
- **Peer-group deviation scoring** — Requires role cluster definition and feature engineering. Medium FP rate during tuning.
- **Entity risk scoring (UEBA)** — Requires 30-day baseline and ongoing tuning. Low FP rate when HR and role context are integrated. Explicitly required by the Desjardins OPC remediation order.
- **CI/CD pipeline tampering detection** — Requires source-control audit integration. Low FP rate.
- **Data staging sequence detection** — Requires correlated process, file, and egress telemetry.
- **After-hours access with sensitive resource correlation** — Requires IdP + HR calendar integration. In async, remote-work, or multi-timezone environments, time-of-day is a near-dead standalone signal with high FP rates; must be paired with identity-context signals (impossible travel, unmanaged device, conditional access failures, MFA anomaly) before enabling automated alerting. Misclassified as Tier 2 in many reference guides.
- **Print volume monitoring** — Requires deliberate PrintService/Operational Event 307 forwarding (non-default in most SIEM deployments), a mature endpoint log pipeline, and a per-user, per-application 90-day baseline. FP rate is high during business cycle peaks (board packs, financial close, audit preparation). Not a Tier 2 control despite frequent reference-guide placement; practical deployment complexity and FP burden place it here.

Tier 4 — Advanced and mature programme (High effort, High precision)

Appropriate only after Tier 1–3 are operational and tuned.

- **Graph analytics on access patterns** — Requires graph infrastructure and edge-history tracking. Research-stage capability for most organisations.
- **Sequence anomaly models (LSTM/transformer)** — Requires labelled training data, feature engineering, and ongoing maintenance. Not a general-availability default.
- **DNS tunneling detection** — Requires full QNAME capture at resolver.
- **Steganography detection in outbound email attachments** — Requires specialised statistical content analysis. No standard DLP product covers this by default.

6. Required Telemetry

No detection programme compensates for missing telemetry. The analytics in §4 require the following log sources to be collected, forwarded to SIEM, and retained for the minimum periods shown.

Identity and access (foundation)

- IdP sign-in logs (Entra ID, Okta, ADFS, Ping): full field set including user UPN, device ID, IP address, ASN, MFA method, session ID, conditional access result. Retention: minimum 1 year.
- Active Directory security audit events: 4624, 4625, 4720, 4728, 4732, 4756, 4740, 4767, 1102 from all domain controllers. Retention: minimum 1 year.
- HR system integration: current employment status, departure date, role, department, manager — fed to SIEM or UEBA within hours of change. This is the most underinvested integration in most programmes and the one with the greatest leverage over detection quality.

Endpoint

- Sysmon deployed with a maintained configuration. Minimum events: 1 (process create with command-line), 2 (file creation time change), 3 (network connection), 7 (image loaded), 11 (file create), 12/13 (registry create/modify), 17 (named pipe create), 22 (DNS query), 23 (file delete — requires Sysmon v7.01+).
- Windows process creation with command-line logging via GPO (Event 4688 + "Include command line in process creation events" policy).
- DLP endpoint agent: removable media events, sensitive file-path access, print operations.

Data and SaaS

- Microsoft 365 Unified Audit Log: all available operations. `MailItemsAccessed` requires Microsoft Purview Audit (Premium). Retention: minimum 1 year (standard tier).
- File server object access (Event 4663) with SACLs on sensitive directories only — applying SACLs to all files generates unmanageable volume.
- CASB or web proxy for personal cloud storage and SaaS upload visibility; HTTPS inspection required for URL-level fidelity.
- SaaS platform audit logs for all production systems (GitHub, GitLab, Slack, Jira, Confluence, Salesforce, Workday, ServiceNow); availability and depth vary by platform and licence tier.

Cloud infrastructure

- AWS CloudTrail: all regions, all management events; S3 data events on sensitive buckets; Lambda invocation logging on production functions.
- Azure Activity Log and Microsoft Defender for Cloud alerts.
- GCP Cloud Audit Logs (Admin Activity; Data Access for sensitive projects).

Network

- Full QNAME DNS resolver logs (Windows DNS debug logging or Zeek dns.log on recursive resolvers; standard Windows Event logs do not contain full query names).
- Web proxy logs with full URI, user-identity attribution (not just IP), and content-type.

HR integration

- Departure dates, with feeds reaching SIEM at least 24 hours before the departure date where feasible.
- Leave calendar.
- Role change events (transfers, promotions, department moves).
- Disciplinary and performance flags (require HR/Legal approval framework before integration with security monitoring in most jurisdictions).

---

7. Legal and Privacy Constraints

Insider threat monitoring operates in legally constrained territory. The following is operational guidance based on publicly available regulatory and legal materials. It is not legal advice. Obtain qualified legal counsel before deploying employee monitoring programmes, particularly for content monitoring, communications interception, or monitoring that extends to personal devices.

United States

The Electronic Communications Privacy Act (ECPA) and the Computer Fraud and Abuse Act (CFAA) generally permit employer monitoring of employer-owned systems, networks, and devices where a legitimate business purpose exists and employees have been notified. The precise legal standard depends on the circuit

and the specific monitoring activity; this is a summary of general principles, not a definitive statement of law. [Documented — ECPA 18 U.S.C. §§ 2510–2523; CFAA 18 U.S.C. § 1030]

An employee's expectation of privacy on corporate devices is reduced — though not eliminated — when: a clear Acceptable Use Policy (AUP) has been communicated, the monitoring is of work systems for stated business purposes, and the policy has been acknowledged in writing. [Inferred from case law; ODNI NITTF guidance [21] provides operational framing]

The NLRB has issued guidance indicating that overly broad monitoring policies that could reasonably be read to prohibit or chill employees' rights to discuss working conditions may be unlawful under the National Labor Relations Act. Consult current NLRB General Counsel guidance for the most recent position, as it changes between administrations. GC 23-02 was explicitly rescinded in February 2025 by Acting General Counsel Cowen via GC 25-05. [25]

CERT's Common Sense Guide adds an operational boundary: do not monitor privileged personal communications (e.g., employee communications with doctors or attorneys); do not target protected disclosures or whistleblower-protected reports through the insider threat programme. [Documented — CERT/CMU 7th ed.]

European Union (GDPR)

Employee monitoring requires a lawful basis under GDPR Article 6, most commonly legitimate interest (Article 6(1)(f)), supported by a documented balancing test demonstrating the security interest outweighs the employee's privacy interest.

Monitoring must be proportionate, purpose-limited (security monitoring data cannot be repurposed for performance management without a separate legal basis), and transparent (employees must be informed). Systematic, high-risk monitoring requires a Data Protection Impact Assessment (DPIA) under Article 35. [Documented — GDPR Articles 6, 13, 35]

Covert monitoring without employee notification is permissible only in limited, documented circumstances — typically where there is specific suspicion of criminal activity and disclosure would prejudice the investigation. Blanket covert monitoring is not supportable under GDPR.

Works council or employee representative consultation is required in many EU member states before deploying monitoring systems; failure to consult may invalidate both the programme and any evidence it produces. The specific requirements vary by member state. [Documented — EDPB guidance; national implementations]

Australia (Privacy Act 1988)

The Privacy Act 1988 currently applies to organisations with annual turnover exceeding AUD 3 million and to all Commonwealth agencies. Note: the Privacy Act Review (2022) recommended expanding coverage to smaller organisations; verify current threshold applicability against the OAIC's published guidance, as the legislative position may have changed. [Documented — Privacy Act 1988; OAIC [23]]

The employee records exemption means that personal information held by private-sector employers in employment records, handled for direct employment-related purposes, is exempt from the Privacy Act's requirements. Monitoring activities extending beyond HR purposes (content monitoring, communications surveillance) may fall under state and territory workplace surveillance legislation, which varies (e.g., New South Wales Workplace Surveillance Act 2005). [Documented — OAIC guidance]

The Australian Privacy Principles require transparency about data collection regardless of the employment records exemption for non-HR data. [Documented — OAIC]

Practical guidance across jurisdictions

- Maintain a current, legally reviewed AUP explicitly notifying employees that corporate systems are monitored, describing monitoring scope.
- Separate security monitoring data from performance management data — they require different legal bases in most jurisdictions.
- Restrict analyst access to monitoring outputs to a defined team (Security, HR, Legal) under documented need-to-know.
- Treat HR-correlated signals (disciplinary history, performance flags) as sensitive data requiring HR and Legal approval before integration with security monitoring.
- Retain records of the legal basis, proportionality assessment, and DPIA for each monitoring activity.
- Ensure human review is in the loop for any adverse employment action derived from monitoring results. Automated risk scores alone are not a sufficient basis for termination or legal referral in any jurisdiction.
- Maintain an access log for who has queried monitoring outputs.

---

8. Implementation Guidance

This phased approach prioritises the highest-value, lowest-effort controls first. Do not skip Phase 1 to reach Phase 3 — the foundational telemetry and legal framework established in Phase 1 are prerequisites for everything that follows.

Phase 1 — Foundations (Months 1–3)

Target outcome: Minimum viable insider detection programme. Would have provided real-time detection or materially shortened investigation time in the Cisco, Yahoo, and Morrisons cases.

1. **HR system integration with IdP**: departure dates, role changes, leave status reaching SIEM within hours of change. This single integration has the greatest leverage over detection quality of any action in this phase.
2. **Enable and forward to SIEM**: IdP sign-in logs (full field set), AD security audit events (4624, 4720, 4728, 1102), AWS CloudTrail (all management events), M365 UAL.
3. **Implement Tier 1 deterministic rules**: post-termination access, audit log clearing, email forwarding to external domain, new privileged account creation, backup deletion outside change window.
4. **Legal and policy foundation**: review and update AUP; engage legal counsel for DPIA or jurisdiction-appropriate assessment; document legal basis for each monitoring activity before enabling it.
5. **Offboarding SLA**: define and enforce a technical offboarding SLA — all accounts disabled and credentials revoked within 4 hours of documented departure. The Cisco/Ramesh case demonstrates the direct cost of missing this.

Phase 2 — Data Exfiltration Coverage (Months 3–6)

Target outcome: Coverage of the most common insider exfiltration paths. Would have provided detection in the Tesla, Levandowski, and Desjardins cases.

1. **Endpoint DLP deployment**: prioritise removable media monitoring and sensitive file-path access logging.
2. **File server SACL configuration**: enable SACLs on sensitive directories; forward Event 4663 to SIEM. Scope carefully — broad SACLs generate unmanageable log volume.

3. **SharePoint/OneDrive download baseline and alerting**: 30-day rolling per-user baseline; count-based anomaly alert.
4. **CASB or proxy personal cloud category**: alerting or blocking for personal cloud storage, with user identity attribution.
5. **Sysmon deployment**: deploy with a maintained configuration (community baselines from SwiftOnSecurity or Florian Roth are commonly used starting points) across endpoints handling sensitive data. Prioritise Events 1, 2, 11, 12, 13, 23.
6. **Departing employee composite rule**: triggered by HR departure date flag + volume anomaly + destination change. Begin with analyst review before automating alert escalation.
7. **Mass deletion threshold alerting**: CloudTrail and Azure Activity Log deletion monitoring; file server deletion count thresholds calibrated per role.

Phase 3 — Behavioural Analytics (Months 6–12)

Target outcome: "Authorised but anomalous" detection coverage for the patterns that deterministic rules cannot reach.

1. **Role-based peer groups**: define user clusters using HR department, job title, and access tier. Validate cluster composition before enabling anomaly scoring.
2. **After-hours access detection**: integrate HR calendar; deploy composite alerting (after-hours + sensitive resource access, not time-of-day alone).
3. **Access outside role scope**: build role-to-resource-path baseline; deploy deviation alerting with a 30-day sensitivity baseline.
4. **Entity risk scoring**: select 5–8 signals and assign each an ordinal risk tier (LOW / MEDIUM / HIGH / CRITICAL, per §4.6); operate in observation-only mode for 30 days before enabling analyst queue entries. Tune false-positive rate before expanding the signal set.
5. **CI/CD pipeline tampering**: integrate source-control audit; configure protected-branch commit alerting and pipeline configuration change monitoring.
6. **Logic bomb artefact alerting**: Windows Security Event 4698 and WMI-Activity/Operational Event 5861 scoped to non-IT accounts; correlate with HR departure status.
7. **Analyst playbook**: create a written escalation process for each alert type that explicitly maps signals to kill-chain phases (planning, staging, exfiltration, sabotage, concealment).

Phase 4 — Mature Programme (Year 2+)

Target outcome: Comprehensive coverage including sophisticated, long-dwell actors.

1. **Graph analytics**: deploy access graph with first-occurrence edge tracking; apply community detection to flag novel access to sensitive resource clusters.
2. **Sequence anomaly models**: for highest-risk role classes (Finance, DBA, sysadmin, cloud engineering) only; build models on longitudinal audit data with careful validation.
3. **HR flag integration**: with Legal and HR approval, integrate disciplinary flag data into risk scoring for specifically elevated-risk accounts.
4. **Quarterly purple-team exercises**: simulate documented case scenarios against the programme; measure time-to-detect and coverage gaps.
5. **Insider Threat Working Group**: cross-functional group (Security + HR + Legal + IT) with defined escalation procedures, investigation protocols, and case management.
6. **Long-retention log storage**: move identity, control-plane, and network device logs to low-cost long-term storage (minimum 3 years). The Desjardins exfiltration lasted 26 months; the Zheng case involved conduct over more than a decade. Short retention windows are an evidence-preservation failure for long-dwell insiders.

---

9. Conclusion and Coverage Gaps

What the evidence shows

Human detection still leads. CERT's banking-and-finance sector study found 61% of insider incidents were detected by non-security personnel and only 22% by auditing or monitoring procedures [4]. The case studies in §3 — drawn predominantly from technology, government, defense, and financial services sectors — are consistent with this directional finding: of the 14 individual incident cases documented in §3.1–3.14 (§3.15 is a CERT pattern set without a specific detection trigger), initial detection came from human observation, external notification, law enforcement referral, or operational failure in the large majority of cases; internal technical monitoring was the primary trigger in at most two to three (Kvashuk, and arguably Twitter/Alzabarah and Yahoo/Ruiz). [Inferred from case records] This is not a statistically representative sample, and the banking-sector percentages should not be read as precise estimates for other industries; however, the pattern is directionally consistent across sectors.

Deterministic rules deliver the best ROI. Post-termination access, audit log clearing, email forwarding rules, and privileged account creation are high-signal, low-noise controls that require minimal tuning. They should be the first investment, not deferred in favour of complex UEBA.

DLP is necessary but routinely insufficient. The case evidence consistently shows DLP failing against: steganographic encoding (GE/Zheng), physical exfiltration (Manning), sub-threshold transfers over extended periods (Desjardins), and channels outside DLP scope (personal cloud sync, SaaS uploads, physical capture). A DLP-only programme misses a majority of documented exfiltration methods.

Dwell time is the central operational problem. The Desjardins insider operated for at least 26 months undetected. Zheng's conduct spanned more than a decade before a counterintelligence referral. The 2023 Ponemon Cost of Insider Risks Global Report found an average of 86 days to contain an insider incident after identification [3]. Detection programmes must account for long-dwell scenarios, require adequate log retention, and must not rely exclusively on volume thresholds. For comparison with external attacker dwell-time trends, see Mandiant's M-Trends 2025 annual report [19].

Privileged users are the highest-risk category. Sysadmins, DBAs, DevOps engineers, cloud admins, and security team members can operate below alert thresholds precisely because they understand the monitoring. This category requires: PAM with session recording, a logging pipeline they cannot access or modify, need-to-know enforcement beyond their administrative role, and tighter change-window controls for their actions.

Coverage gaps — what standard enterprise tooling cannot currently detect

Steganographic exfiltration. Files hidden in image, audio, or video payloads. No standard DLP product detects this without specialised statistical content analysis. The GE/Zheng case ran over a decade without internal detection.

Physical exfiltration. Photographing a monitor with a personal device, removing printed documents, verbally memorising credentials. No technical detection is possible. Process controls (clear-desk policy, no-photography zones, escorted access to data rooms) are the only mitigations.

Social engineering of a peer. The insider obtains sensitive data by convincing a colleague to send it on their behalf. The insider's account generates no anomalous activity. Detection requires monitoring of the unwitting colleague's outbound behaviour.

Very slow, low-volume exfiltration. One document per week for 18 months stays below every standard volume threshold. The only effective detection is sensitivity-aware (any movement of a specific classification label triggers review) or graph-based (first-ever access to a document cluster outside the user's normal community).

Insider with knowledge of the detection programme. A SIEM administrator, security engineer, or detection engineer who knows which rules are deployed and operates below all thresholds. Requires a separate, independent monitoring pipeline and oversight from outside the security team.

Nation-state planted insiders. Trained, patient actors who maintain legitimate behavioural envelopes for extended periods. The GE/Zheng case required a counterintelligence referral to surface. Technical controls alone are insufficient; counterintelligence partnership is required.

Personal devices and unmanaged networks. BYOD environments and personal cloud accounts accessed outside corporate networks are largely outside corporate monitoring scope. Data moved to a managed corporate device and then transferred to a personal cloud account via a personal mobile hotspot generates minimal corporate telemetry.

---

10. References

The following primary sources are cited in this guide. For DOJ criminal matters, press releases and criminal complaints are cited; where the original filing URL has changed, the relevant DOJ press office page is provided as an entry point. Note that [5] and [6] are based on publicly available secondary sources; primary government documents in those cases are partially restricted or not available in consolidated public form. References [1] and [2] are supplementary industry survey context cited in §1; they are not primary sources for detection claims.

[1] Cybersecurity Insiders. *2024 Insider Threat Report*. 2024. https://www.cybersecurity-insiders.com/portfolio/insider-threat-report/
(Self-reported industry survey; methodology and sampling are not independently audited. Use statistics with appropriate caveats.)

[2] Verizon. *2025 Data Breach Investigations Report*. 2025. https://www.verizon.com/business/resources/reports/dbir/
(DBIR "internal actor" category includes both malicious insiders and negligent human error. Not all internal-actor incidents represent malicious insider cases.)

[3] Ponemon Institute / DTEX Systems. *2023 Cost of Insider Risks Global Report*. 2023. https://www.dtexsystems.com/resource/2023-insider-risk-report/ *(Sponsored research; available via DTEX Systems' resources page — confirm the URL is current. Self-selected survey methodology; reported figures reflect participating organisations only.)*

[4] Carnegie Mellon University SEI CERT Division. *Common Sense Guide to Mitigating Insider Threats, Seventh Edition*. 2022. https://resources.sei.cmu.edu/library/asset-view.cfm?assetid=552459
(Primary source for CERT case statistics, taxonomy, kill chain model, and sector study statistics cited throughout this guide.)

[5] US Army / DOJ. *United States v. Bradley (Chelsea) Manning*. Court-martial record, 2013. Manning v. United States, subsequent legal proceedings.
(Primary court-martial records and DOJ charging documents are the authoritative source; secondary reporting available via archived news sources. Congressional hearing findings referenced via Armed Services Committee record.)

[6] NSA Office of Inspector General. *Report on the Unauthorized Disclosure of Classified Information by Edward Snowden* (partially declassified). 2016.
(NSA OIG report is the primary source; available in partially declassified form. Secondary consolidated coverage via ODNI and congressional record.)

[7] US Department of Justice, USAO Northern District of California. *United States v. Sudhish Kasaba Ramesh*. Press release, 2020. https://www.justice.gov/usao-ndca/pr/former-cisco-engineer-sentenced-two-years-federal-prison-intentionally-damaging

[8] US Department of Justice. *United States v. Xiaoqing Zheng*. Indictment, 2019; Conviction press release, 2023. https://www.justice.gov/opa/pr/ge-engineer-and-chinese-businessman-charged-economic-espionage-and-theft-trade-secrets

[9] US Department of Justice, SDNY. *United States v. Nickolas Sharp*. Press release, 2023. https://www.justice.gov/usao-sdny/pr/former-employee-ubiquiti-sentenced-six-years-prison-stealing-confidential-data-and

[10] Tesla, Inc. v. Tripp and related proceedings; Handelsblatt reporting, 2023. *(Primary legal filings are the authoritative source; Handelsblatt and Tesla legal disclosures are cited as secondary sources in the absence of a consolidated public primary document.)*

[11] US Department of Justice, USAO District of New Jersey. *United States v. Roger Duronio*. Press release and sentencing documents, 2006. https://www.justice.gov/archive/usao/nj/Press/files/pdffiles/Duroniosen.pdf

[12] US Department of Justice, USAO Northern District of California. *United States v. Anthony Scott Levandowski*. Press release, 2020. https://www.justice.gov/usao-ndca/pr/google-self-driving-car-engineer-pleads-guilty-federal-trade-secret-theft-charges

[13] UK Supreme Court. *Wm Morrison Supermarkets plc v Various Claimants* [2020] UKSC 12. https://www.supremecourt.uk/cases/uksc-2018-0090.html

(The Supreme Court reversed Court of Appeal findings of vicarious liability and held Morrisons was NOT vicariously liable.)

[14] US Department of Justice, USAO Northern District of California. *United States v. Reyes Daniel Ruiz*. Press release, 2019. https://www.justice.gov/usao-ndca/pr/former-yahoo-employee-pleads-guilty-computer-intrusion

[15] US Department of Justice, USAO Western District of Washington. *United States v. Volodymyr Kvashuk*. Press release, 2020. https://www.justice.gov/usao-wdwa/pr/software-engineer-sentenced-9-years-defrauding-microsoft-10-million

[16] Office of the Privacy Commissioner of Canada. *Investigation Report into Desjardins Group's compliance with PIPEDA*, 2020-001. 2020. https://www.priv.gc.ca/en/opc-actions-and-decisions/investigations/investigations-into-businesses/2020/pipeda-2020-001/

[17] US Department of Justice, USAO Northern District of California. *United States v. Ahmad Abouammo*. Press release and verdict, 2022. https://www.justice.gov/usao-ndca/pr/former-twitter-employee-found-guilty-acting-agent-foreign-government-kingdom-saudi

[18] US Department of Justice, USAO Southern District of New York. *Former Employee Of New York Credit Union Charged With Unauthorized Computer Access And Intentional Damage To A Protected Computer*. Press release, 2021. https://www.justice.gov/usao-sdny/pr/former-employee-new-york-credit-union-charged-unauthorized-computer-access-and

[19] Mandiant / Google Cloud Security. *M-Trends 2025: Threat Intelligence Report*. 2025. https://cloud.google.com/blog/topics/threat-intelligence/m-trends-2025 *(Landing page and download registration for the full report. Published annually; cited for external attacker dwell-time comparisons and enterprise detection trend context.)*

[20] CISA. *Insider Threat Mitigation Guide*. 2020. https://www.cisa.gov/resources-tools/resources/insider-threat-mitigation-guide

[21] ODNI National Insider Threat Task Force. *Insider Threat Program Maturity Framework*. 2018. https://www.dni.gov/files/NCSC/documents/nittf/NITTF_Insider_Threat_Program_Maturity_Framework.pdf *(Operational guidance framework for US government programmes; referenced for monitoring boundary guidance, not as legal authority.)*

[22] European Data Protection Board / Official GDPR text. Articles 6, 13, 35. https://gdpr-info.eu/

[23] Office of the Australian Information Commissioner. *Employee Records Exemption*. https://www.oaic.gov.au/privacy/privacy-guidance-for-organisations-and-government-agencies/workplace-

privacy/employee-records-exemption

[24] Mandiant (formerly FireEye). *SUNBURST Additional Technical Details*. December 2020. https://www.fireeye.com/blog/threat-research/2020/12/sunburst-additional-technical-details.html *(Original publication URL; archived at the Internet Archive Wayback Machine as the fireeye.com domain was retired following the FireEye → Mandiant → Google Cloud rebrand sequence. Cited for the documented use of a low-entropy subdomain DGA in the C2 channel, which evades DNS entropy-based detection heuristics.)*

[25] National Labor Relations Board, Office of the General Counsel. *Electronic Monitoring and Algorithmic Management of Employees That Implicates the National Labor Relations Act*. GC 23-02. October 2022. https://www.nlrb.gov/news-outreach/news-story/nlrb-general-counsel-issues-memo-on-electronic-monitoring *(GC memos reflect the position of the General Counsel, not binding NLRB precedent. Note: GC 23-02 was rescinded in February 2025 by Acting GC Cowen via GC 25-05. The memo is cited as a documented point-in-time position on electronic monitoring; it no longer reflects current NLRB GC guidance.)*

↑ Back to top